



Site: <https://geston-hospitalaria.vercel.app>

Generated on Mon, 28 Sept 2026 23:42:07

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	4
Informational	8
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of responses with status code 2xx	71 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of responses with status code 4xx	28 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of endpoints with content type application/javascript	20 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of endpoints with content type image/svg+xml	20 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of endpoints with content type text/css	20 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of endpoints with content type text/plain	40 %
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of endpoints with method GET	100 %
Info	Informational	https://geston-hospitalaria.vercel.app	Count of total endpoints	5
Info	Informational	https://geston-hospitalaria.vercel.app	Percentage of slow responses	42 %

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	1
Cross-Domain Misconfiguration	Medium	4
Missing Anti-clickjacking Header	Medium	1
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	1
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	1
Permissions Policy Header Not Set	Low	2
X-Content-Type-Options Header Missing	Low	4
Modern Web Application	Informational	1
Re-examine Cache-control Directives	Informational	1
Retrieved from Cache	Informational	4
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3
Sec-Fetch-Site Header is Missing	Informational	1
Sec-Fetch-User Header is Missing	Informational	3
Storable but Non-Cacheable Content	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Node Name	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Node Name	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains,

Other Info	using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://geston-hospitalaria.vercel.app/favicon.svg
Node Name	https://geston-hospitalaria.vercel.app/favicon.svg
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	4
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	1
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Cross-Origin-Embedder-Policy Header Missing or Invalid
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-

	Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Opener-Policy Header Missing or Invalid
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Permissions Policy Header Not Set
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Node Name	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Node Name	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Node Name	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://geston-hospitalaria.vercel.app/favicon.svg
Node Name	https://geston-hospitalaria.vercel.app/favicon.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.

URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-BJambGXP.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	cache-control
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
Instances	1
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Node Name	https://geston-hospitalaria.vercel.app/assets/index-BJambGXP.js
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Node Name	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Method	GET

Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://geston-hospitalaria.vercel.app/favicon.svg
Node Name	https://geston-hospitalaria.vercel.app/favicon.svg
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	4
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/robots.txt
Node Name	https://geston-hospitalaria.vercel.app/robots.txt
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/sitemap.xml
Node Name	https://geston-hospitalaria.vercel.app/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest

CWE Id	352
WASC Id	9
Plugin Id	90005
Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/robots.txt
Node Name	https://geston-hospitalaria.vercel.app/robots.txt
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/sitemap.xml
Node Name	https://geston-hospitalaria.vercel.app/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app

Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/robots.txt
Node Name	https://geston-hospitalaria.vercel.app/robots.txt
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	https://geston-hospitalaria.vercel.app/sitemap.xml
Node Name	https://geston-hospitalaria.vercel.app/sitemap.xml
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Storable but Non-Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.
URL	https://geston-hospitalaria.vercel.app
Node Name	https://geston-hospitalaria.vercel.app
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Node Name	https://geston-hospitalaria.vercel.app/assets/index-CBTGK4aP.css
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://geston-hospitalaria.vercel.app/favicon.svg
Node Name	https://geston-hospitalaria.vercel.app/favicon.svg
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://geston-hospitalaria.vercel.app/robots.txt
Node Name	https://geston-hospitalaria.vercel.app/robots.txt
Method	GET

Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://geston-hospitalaria.vercel.app/sitemap.xml
Node Name	https://geston-hospitalaria.vercel.app/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
Instances	Systemic
Solution	
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.